SSRF

Server-Side Request Forgery

tricking the server into making a request on your behalf.

Common Parameters to Test:

- url=
- path=
- redirect=
- callback=
- api=
- uri=
- dest=
- file=
- image=

SSRF Bypass Tricks

- *Encoding / Obfuscation*

  http://127.0.0.1
  http://localhost
  http://2130706433
  http://0x7f000001

- *DNS Trick*

  http://127.0.0.1.nip.io

  bypass filters

Basic Defenses

- block internal IP ranges
- allowlist domains
- disable unnecessary protocols
- validate + resolve DNS properly

The takeaway

- SSRF = server becomes your proxy
- localhost + metadata = targets
- bypasses = where the real game is

Mini Workflow 4 Labs

1. Find input (url, image, api, etc)
2. Try: http://127.0.0.1
3. Try bypasses (hex, decimal, nip.io)
4. Try internal IPs
5. Try metadata:

   http://169.254.169.254/
6. Check responses

Signs of SSRF

- response changes
- internal data
- timeout / different error
- unexpected HTML/API response

When SSRF appends stuff:
Use & → start new parameter
Use x= → absorb garbage
Use encoding → fix nested URLs

METADATA (HIGH VALUE) = http://169.254.169.254/